

Pergunta 1:

Uma empresa está criando um conjunto de políticas de segurança da informação. Durante o processo, uma equipe de TI analisa as necessidades de controle de acesso e segurança de dados. Uma das políticas propostas abrange a definição de requisitos de segurança para todos os funcionários, incluindo a utilização de senhas fortes e a restrição de acesso a dados sensíveis com base em funções específicas.

Qual é o principal objetivo dessa política?

Resposta correta: c. Proteger dados sensíveis e garantir a integridade dos sistemas.

- **Explicação:** A política descrita tem o objetivo de **proteger dados sensíveis** (com medidas como senhas fortes e restrição de acesso) e **garantir a integridade dos sistemas**, ou seja, assegurar que apenas usuários autorizados acessem dados críticos. Essas medidas garantem a **confidencialidade** e a **integridade** das informações.
 - **Outras alternativas erradas:**
 - **a. Garantir a conformidade com a LGPD:** A LGPD trata da proteção de dados pessoais, mas a pergunta foca em **segurança de acesso e proteção dos dados sensíveis**, que vai além da conformidade com a LGPD.
 - **b. Definir critérios de monitoramento de sistemas:** A política mencionada não trata diretamente de monitoramento, mas de **controle de acesso e segurança de dados**.
 - **d. Melhorar a eficiência operacional:** O objetivo principal não é **eficiência operacional**, mas sim proteger **dados sensíveis** e garantir a **integridade dos sistemas**.
 - **e. Aumentar a disponibilidade de informações:** A disponibilidade é importante, mas o foco da questão está em **proteger dados sensíveis** e **garantir a segurança do acesso**.
-

Pergunta 2:

Durante uma auditoria de segurança, a equipe de TI de uma empresa estabelece que seus processos de autenticação não envolveram acordo com as melhores práticas de segurança, como o uso de senhas fortes e autenticação multifatorial. A empresa decide implementar essas melhorias para aumentar a proteção contra acessos não autorizados.

Qual princípio de segurança da informação está sendo abordado com essa mudança?

Resposta correta: **b. Confidencialidade**

- **Explicação:** A implementação de **senhas fortes** e **autenticação multifatorial** tem o objetivo de **proteger a confidencialidade dos dados**, garantindo que somente usuários autorizados possam acessar informações sensíveis. Isso impede acessos não autorizados, mantendo a confidencialidade.
 - **Outras alternativas erradas:**
 - **a. Disponibilidade:** O foco está na **proteção contra acessos não autorizados**, não na **disponibilidade** dos dados.
 - **c. Integridade:** Embora a integridade dos dados também seja importante, o foco principal da pergunta é **proteger a confidencialidade** através de controles de autenticação.
 - **d. Resiliência:** Resiliência está relacionada à capacidade de um sistema se recuperar de incidentes, não diretamente à **proteção de dados** contra acessos não autorizados.
 - **e. Autenticidade:** A **autenticidade** refere-se à verificação da identidade do usuário, mas o principal objetivo aqui é **garantir a confidencialidade dos dados**, não apenas verificar se o usuário é legítimo.
-

Pergunta 3:

Uma empresa de fintech decidiu implementar um sistema de auditoria contínua para monitorar o acesso e a alteração de dados financeiros sensíveis. Além disso, a empresa estabelece regras claras para garantir que qualquer atividade suspeita seja reportada imediatamente à equipe de segurança.

Qual é o principal objetivo desses auditórios contínuos?

Resposta correta: c. Monitorar e identificar acessos não autorizados ou atividades suspeitas.

- **Explicação:** O **objetivo principal** de auditorias contínuas é **monitorar e identificar atividades suspeitas ou acessos não autorizados** em tempo real. Isso ajuda a detectar rapidamente qualquer ação maliciosa ou fora do padrão, protegendo dados financeiros sensíveis.
- **Outras alternativas erradas:**
 - **a. Aumentar a disponibilidade dos dados financeiros:** O foco da auditoria não é garantir a **disponibilidade**, mas monitorar o comportamento no sistema para **identificar atividades suspeitas**.
 - **b. Melhorar o processo de backup de dados:** O objetivo da auditoria não é relacionado a **backup** de dados, mas à **monitorização de acessos**.
 - **d. Facilitar a recuperação de dados após incidentes:** A auditoria não tem o foco na **recuperação de dados**, mas sim na **detecção de acessos não autorizados**.
 - **e. Reduzir o custo com recursos de TI:** O principal objetivo da auditoria é a **segurança e monitoramento** dos dados, não necessariamente a redução de custos.

Pergunta 4:

Durante uma análise de riscos, uma empresa acordou que um dos maiores riscos à segurança da informação era a falta de treinamento adequado para os funcionários sobre as políticas de segurança. Em resposta, a empresa decidiu implementar treinamentos regulares e realizar simulações de incidentes de segurança para testar a ocorrência dos funcionários.

Qual é o principal objetivo dessa ação?

Resposta correta: c. Reduzir o impacto de ataques cibernéticos através da conscientização dos funcionários.

- **Explicação:** A principal **ação** descrita é a **educação e conscientização** dos funcionários para reduzir o risco de **erros humanos** que podem facilitar ataques cibernéticos, como phishing, e assim diminuir o impacto de incidentes.
- **Outras alternativas erradas:**

- **a. Melhorar a eficiência operacional:** A conscientização sobre segurança tem como objetivo a **redução de riscos**, não a **eficiência operacional**.
 - **b. Garantir a conformidade com regulamentações externas:** Embora a conformidade seja importante, o principal objetivo aqui é **reduzir o risco de incidentes** por meio da educação dos funcionários.
 - **d. Aumentar a capacidade de recuperação de dados:** O foco não está em **recuperação de dados**, mas em **evitar incidentes de segurança**.
 - **e. Proteger os dados sensíveis contra ataques externos:** O foco aqui é **reduzir erros humanos** e **aumentar a conscientização**, não a proteção de dados diretamente.
-

Pergunta 5:

Após a implementação de uma política de segurança de dados, uma empresa começa a realizar auditorias periódicas para avaliar a eficácia dessa política. As auditorias incluem a verificação de registros de acesso e a avaliação das configurações de segurança dos sistemas.

Qual é o principal benefício de realizar essas auditorias periódicas?

Resposta correta: d. Verificar a conformidade com a política de segurança e identificar vulnerabilidades.

- **Explicação:** O principal objetivo das auditorias periódicas é **verificar se as políticas de segurança estão sendo seguidas corretamente**, bem como **identificar vulnerabilidades** que possam ser corrigidas para melhorar a segurança.
- **Outras alternativas erradas:**
 - **a. Garantir a continuidade das operações comerciais:** O foco das auditorias não é **garantir continuidade**, mas **avaliar a conformidade** com a política de segurança.
 - **b. Identificar falhas na infraestrutura de TI:** Embora as auditorias possam identificar falhas, o **objetivo principal** é verificar a conformidade com a política de segurança.

- **c. Melhorar o desempenho dos sistemas:** O foco das auditorias não é melhorar o **desempenho dos sistemas**, mas sim **avaliar a segurança**.
 - **e. Reduzir o custo operacional de TI:** O objetivo das auditorias não é **reduzir custos**, mas garantir que a segurança esteja sendo mantida.
-

Pergunta 6:

Uma grande empresa está criando uma nova política de gestão de incidentes de segurança. A equipe de segurança cibernética trabalha para definir as etapas que devem ser seguidas quando ocorre um incidente, como identificar, conter e resolver rapidamente as ameaças.

Qual é o principal objetivo de uma política de gestão de incidentes?

Resposta correta: **b. Minimizar os danos e a perda de dados durante um incidente.**

- **Explicação:** A principal função de uma **política de gestão de incidentes** é garantir que, quando ocorrerem incidentes de segurança, a empresa consiga **minimizar danos e reduzir a perda de dados**. Isso envolve responder rapidamente, identificar a causa do problema e aplicar ações corretivas.
 - **Outras alternativas erradas:**
 - **a. Melhorar o desempenho do sistema de TI:** A política de gestão de incidentes não tem como objetivo **melhorar o desempenho dos sistemas**, mas **responder e minimizar o impacto de incidentes**.
 - **c. Aumentar o ritmo de atividade dos sistemas:** Novamente, o foco não é **aumentar a atividade**, mas sim **reduzir os impactos de um incidente**.
 - **d. Reduzir os custos com segurança:** O objetivo não é **reduzir custos**, mas sim garantir que a resposta ao incidente seja eficiente e minimize danos.
 - **e. Garantir a integridade dos dados após o incidente:** Embora a integridade dos dados seja importante, o foco principal é **minimizar danos** durante o incidente.
-

Pergunta 7:

Um cliente corporativo solicita que a empresa forneça um relatório detalhado sobre as medidas de segurança que estão sendo aplicadas para proteger os dados pessoais dos consumidores. A equipe de segurança prepara o relatório, detalhando os controles de acesso, as práticas de criptografia e as auditorias realizadas.

Qual documento a empresa está criando para atender a essa solicitação?

Resposta correta: d. Relatório de conformidade com a LGPD.

- **Explicação:** A solicitação do cliente está relacionada à **conformidade com a LGPD**, que é a **Lei Geral de Proteção de Dados** do Brasil. O relatório detalha as **medidas de segurança** implementadas pela empresa para garantir a **proteção de dados pessoais** dos consumidores, o que está diretamente alinhado com os requisitos da LGPD.
 - **Outras alternativas erradas:**
 - **a. Relatório de impacto de proteção de dados (DPIA):** O DPIA é um documento específico que avalia riscos de privacidade, não sendo o foco principal aqui. A pergunta está mais relacionada a **conformidade com a LGPD**.
 - **b. Relatório de incidentes de segurança:** O relatório mencionado não é sobre **incidentes de segurança**, mas sim sobre **medidas de segurança** para proteger os dados.
 - **c. Política de segurança da informação:** A política de segurança da informação pode ser uma **diretriz interna**, mas o cliente está pedindo um **relatório de conformidade**, ou seja, um documento específico para mostrar como a empresa **atende à LGPD**.
 - **e. Auditoria de segurança interna:** A auditoria de segurança interna é uma prática interna da empresa, enquanto o cliente está pedindo um **relatório de conformidade** que explica as **medidas de proteção** de dados pessoais.
-

Pergunta 8:

Após realizar uma análise de riscos, uma empresa decidiu implementar uma política de segurança em camadas, incluindo o uso de firewalls, antivírus, criptografia e controle de acesso.

O que a empresa está priorizando ao adotar essa abordagem?

Resposta correta: b. Proteger os dados contra acesso não autorizado.

- **Explicação:** A empresa está implementando uma abordagem de **segurança em camadas**, o que significa que ela usa **vários controles de segurança**, como **firewalls, antivírus, criptografia e controle de acesso**, para **proteger dados contra acessos não autorizados**. Isso aumenta a segurança, dificultando que um único ponto de falha comprometa o sistema.
- **Outras alternativas erradas:**
 - **a. Melhorar a integridade dos dados:** Embora a **integridade dos dados** seja importante, o foco da segurança em camadas é **proteger dados contra acessos não autorizados** e garantir a **segurança geral** do sistema.
 - **c. Aumentar a confiabilidade dos sistemas:** A confiabilidade é importante, mas a **segurança em camadas** foca em **proteger contra acessos não autorizados**.
 - **d. Garantir a disponibilidade dos sistemas:** A **disponibilidade** é um objetivo secundário, mas a principal ênfase está na **proteção de dados** contra acessos não autorizados.
 - **e. Reduzir o custo operacional:** O foco não é **reduzir custos**, mas sim garantir que as informações estejam **seguras** contra acessos não autorizados.

Pergunta 9:

Durante uma auditoria de segurança, uma equipe de TI descobriu que as configurações de segurança em um servidor não foram atualizadas corretamente, ou que deixaram o sistema vulnerável a um ataque. A equipe recomenda a implementação de um processo de gerenciamento de configurações de segurança para garantir que todas as configurações sejam mantidas de acordo com as melhores práticas.

Qual é o principal objetivo do gerenciamento de configurações de segurança?

Resposta correta: b. Garantir que as configurações de segurança estejam em conformidade com as políticas de segurança.

- **Explicação:** O objetivo do **gerenciamento de configurações de segurança** é garantir que as configurações de todos os sistemas estejam **de acordo com as melhores práticas de segurança** e as **políticas de segurança** da organização. Isso ajuda a minimizar vulnerabilidades e mantém os sistemas seguros.
 - **Outras alternativas erradas:**
 - **a. Aumentar o ritmo de atividade do servidor:** O gerenciamento de configurações não tem como objetivo **aumentar o desempenho**, mas sim **manter a segurança das configurações**.
 - **c. Reduzir o custo de manutenção dos sistemas:** Embora o gerenciamento de configurações possa ajudar a **reduzir riscos**, seu foco principal não é **reduzir custos**, mas garantir que as configurações de segurança estejam em conformidade com as políticas.
 - **d. Melhorar a eficiência operacional da equipe de TI:** O objetivo não é melhorar a **eficiência operacional**, mas garantir que as **configurações de segurança** estejam corretas.
 - **e. Aumentar a complexidade da infraestrutura de TI:** O foco do gerenciamento de configurações é melhorar a **segurança**, não aumentar a complexidade da infraestrutura.
-

Pergunta 10:

Durante uma auditoria de segurança, a equipe descobre que os dados privados de clientes estão sendo armazenados sem a criptografia devida. Como resposta, a empresa implementa uma política de criptografia obrigatória para todos os dados sensíveis, tanto em segurança quanto em trânsito.

Qual princípio da cibersegurança está sendo abordado com a correção dessa política?

Resposta correta: a. Confidencialidade.

- **Explicação:** A **criptografia obrigatória** dos dados sensíveis tem como objetivo principal garantir a **confidencialidade** dos dados, ou seja, impedir

que informações privadas sejam acessadas por pessoas não autorizadas, mesmo que sejam interceptadas durante o armazenamento ou trânsito.

- **Outras alternativas erradas:**

- **b. Disponibilidade:** A criptografia foca em garantir que os dados não sejam acessados por terceiros não autorizados, não necessariamente em melhorar a **disponibilidade** dos dados.
 - **c. Integridade:** Embora a criptografia ajude a proteger a **integridade** dos dados, o foco principal da pergunta é a **confidencialidade**.
 - **d. Autenticação:** A autenticação está relacionada à **verificação de identidade** de usuários, não à proteção dos dados em si.
 - **e. Resiliência organizacional:** A resiliência organizacional está mais relacionada à **capacidade de recuperação** e continuidade após um incidente, enquanto a criptografia aborda a **proteção de dados confidenciais**.
-